

TLS Guide: Wireshark Analysis of TLS Traffic

What is TLS?

TLS (Transport Layer Security) is the successor to SSL. It provides **encryption, authentication, and integrity** for network communications. HTTPS, SMTPS, FTPS, and many other secure protocols are actually TLS-protected.

In Wireshark, you can analyze the **TLS handshake** even when you cannot decrypt the actual application data.

Typical Ports

- **TCP 443** — HTTPS (most common)
- **TCP 465** — SMTPS
- **TCP 993** — IMAPS
- **TCP 995** — POP3S

Why Analysts Care About TLS

- Most modern web traffic is encrypted with TLS.
- The handshake reveals a lot of metadata (server identity, cipher suites, certificates).
- Misconfigurations (weak ciphers, expired certificates, poor key exchange) are common.
- Certificate analysis helps detect phishing and man-in-the-middle attacks.
- Understanding TLS is essential before moving to advanced topics like decryption.

TLS Handshake Breakdown (Most Important Part)

1. **Client Hello**
 - Supported TLS versions
 - Cipher suites offered
 - Server Name Indication (**SNI**)
 - Extensions
2. **Server Hello**
 - Chosen TLS version and cipher suite
 - Server certificate
3. **Certificate** (from Server)
 - Server's public certificate chain
4. **Server Key Exchange** (if needed)
5. **Server Hello Done**
6. **Client Key Exchange**
7. **Change Cipher Spec + Encrypted Handshake Message** (both sides)
8. **Application Data** — Encrypted traffic begins

Wireshark Fundamentals for TLS Analysis

1. Basic Filtering

Bash

```
tls # All TLS traffic
tls.handshake # Handshake messages only
tls.handshake.type == 1 # Client Hello
tls.handshake.type == 2 # Server Hello
tls.handshake.type == 11 # Certificate
tls.handshake.extensions_server_name contains "example.com" # SNI
tls.record.version # TLS version
```

2. Key Fields to Examine

Client Hello

- Server Name Indication (SNI) — Which domain the client is trying to reach
- Offered cipher suites
- Supported TLS versions

Server Hello

- Chosen cipher suite
- Selected TLS version (1.2, 1.3, etc.)

Certificate

- Subject (Common Name)
- Issuer
- Validity dates (Not Before / Not After)
- Public Key Algorithm
- Certificate chain

Application Data

- Encrypted payload (usually unreadable without decryption)

Common TLS Analysis Scenarios in Thaghrach Challenges

1. **Certificate Analysis**
 - Check for self-signed, expired, or mismatched certificates.
2. **SNI Inspection**
 - Identify which website the user was visiting.
3. **Weak Cipher Detection**
 - Spot use of deprecated ciphers (e.g., RC4, 3DES, MD5).
4. **TLS Version Analysis**
 - Identify outdated TLS 1.0 or 1.1 usage.
5. **Handshake Failures**
 - Analyze why a TLS connection failed.
6. **Mixed Traffic**
 - TLS combined with HTTP, DNS, etc.

Practical Workflow in Wireshark

1. Filter `tls or tcp.port == 443`.
2. Expand the first few packets to see the handshake.
3. Right-click a **Client Hello** → **Follow** → **TCP Stream** to see the full session.
4. Go to the **Certificate** packet and expand all certificate details.
5. Use **Statistics** → **TLS** for an overview of versions and ciphers used.
6. For decryption (advanced):
 - Export keys if available (SSLKEYLOGFILE)
 - Right-click → **Protocol Preferences** → TLS → RSA keys list

Security Red Flags in TLS Traffic

- Missing or invalid certificates.
- Self-signed certificates in production.
- Very old TLS versions (1.0 or 1.1).
- Weak cipher suites.
- SNI not matching certificate Common Name.
- Certificate issued to suspicious domains.

Example Challenge Goals You Will Encounter

- Identify the domain the user was visiting using **SNI**.
- Extract and analyze the server certificate.
- Determine if the connection is using secure TLS settings.
- Find the flag hidden in the certificate details or handshake metadata.
- Spot a man-in-the-middle attempt or certificate mismatch.

Tips for Thaghras Students:

- You usually **cannot read the encrypted data**, but the handshake is very informative.
- Always check the **SNI** in Client Hello and the **Certificate** chain.
- TLS 1.3 is different (fewer visible fields) — most challenges will use TLS 1.2 for teaching purposes.
- Pay close attention to certificate fields — flags are sometimes cleverly placed there.